ELECTORAL COMMISSION OF ZAMBIA

Incident Response

Electoral Commission of Zambia (ECZ) Phishing Attack

Document type: Incident Response Report

Incident status: **Resolved**

Documentation date: September 8, 2026

Classification: Public - Real-world case

Reporter: Paul Mumbi (mumbipaul02@gmail.com)



A real-case study of a live phishing incident

Contents

Executive summary **3**
Incident timeline **3**
Technical analysis **4**
1. Discovery method 4
2. Repository analysis 4
3. Malicious code analysis 5
4. Infrastructure mapping 5
Attack profile **6**
Target 6
Threat indicators 6
Potential victim impact 6
Incident response process **6**
Step 1: Evidence gathering 6
Step 2: Documentation 7
Step 3: Multi-channel reporting 7
Step 4: Tracking and follow-up 8
GitHub's response **9**
Official confirmation 9
Actions confirmed 9
Violations found 9
Incident resolution **10**
What was stopped 10
Residual actions (optional) 10
Incident response methodology used **11**
Framework applied 11
Key process strengths 11
Lessons learned **12**
What worked well 12
Areas for future improvement 12
Threat intelligence insights 13
Real-case study **13**
What this case demonstrates 13
Real-world impact 14
Appendix: Supporting evidence **14**
DNS resolution output 14
GitHub confirmation email 15
Document history **15**

Executive summary

This document chronicles the complete incident lifecycle from discovery through resolution of a sophisticated phishing attack impersonating the Electoral Commission of Zambia. The attack was hosted on GitHub Pages and targeted Zambian citizens seeking government employment.

The investigation started from a real phishing email and was carried out using open-source intelligence (OSINT) techniques. The findings were then reported to GitHub, which acted on them.

Outcome: Account suspended, repository removed, malicious domain neutralized.

Incident timeline

Response Time: About 5 months (April 2 to September 8, 2026)

Date	Action	Details
Apr 2, 2026	**Discovery**	Identified phishing site impersonating ECZ
Apr 2, 2026	**Analysis**	Conducted DNS resolution and repository inspection
Apr 2, 2026	**Documentation**	Compiled formal incident report with technical evidence
Apr 2, 2026	**Reporting**	Submitted to GitHub Abuse Report form
Apr 2, 2026	**Follow-up**	Email sent to abuse@github.com
Sep 8, 2026	**Confirmation**	GitHub Trust & Safety confirmed action taken
Sep 8, 2026	**Resolution**	Account suspended, repository removed, case closed

Technical analysis

1. Discovery method

Initial Observation:

- Domain: ecz-career.alloffer.org claimed to be Electoral Commission of Zambia careers portal
- Appeared suspicious due to non-official domain structure
- Warranted immediate DNS investigation

DNS Resolution:

```
$ nslookup ecz-career.alloffer.org

Server:         127.0.0.53
Address:        127.0.0.53#53

Non-authoritative answer:
ecz-career.alloffer.org    canonical name = kenblogme.github.io
Name:   kenblogme.github.io
Address: 185.199.109.153
Address: 185.199.108.153
Address: 185.199.111.153
Address: 185.199.110.153

IPv6 Addresses:
2606:50c0:8000::153
2606:50c0:8003::153
2606:50c0:8002::153
2606:50c0:8001::153
```

Finding: Domain CNAME resolves to kenblogme.github.io (GitHub Pages CDN infrastructure)

2. Repository analysis

Account: kenblogme

Repository: kenblogme.github.io

Hosting: GitHub Pages

Commits: 24 total

Last Update: 1 week prior to discovery

Malicious Files Identified:

File	Purpose	Malicious Intent
CNAME	Custom domain configuration	Enables domain spoofing
job.html	Fake job listings page	Deception/legitimacy facade
offer.js	JavaScript form handler	Credential capture and exfiltration
staff.html	Fake staff directory	Social engineering / trust building

3. Malicious code analysis

Offer.js Functionality:

- Captures form submissions from job.html
- Exfiltrates credentials and personal information
- Likely sends data to attacker-controlled server
- Demonstrates premeditated credential harvesting

Attack Chain:

1. Victim visits ecz-career.alloffer.org
2. Sees legitimate-looking ECZ branding and job listings
3. Fills out application form with credentials/personal info
4. offer.js captures and transmits data
5. Attacker gains access to credentials

4. Infrastructure mapping

DNS Chain:

```
ecz-career.alloffer.org
   ↓ (CNAME)
kenblogme.github.io
   ↓ (GitHub Pages CDN)
185.199.108.153 to 185.199.111.153 (GitHub Pages IPs)
```

Hosting Advantage for Attacker:

- GitHub Pages is free and widely trusted
- CNAME allows domain spoofing

- GitHub CDN masks attacker's true infrastructure
- Difficult for average user to detect

Attack profile

Target

- **Entity Impersonated:** Electoral Commission of Zambia (Government Institution)
- **Victim Demographic:** Zambian citizens seeking government employment
- **Geographic Focus:** Zambia
- **Sophistication:** Medium (domain spoofing + credential harvesting)

Threat indicators

- Government branding misuse
- Fake recruitment portal
- Custom domain configuration
- JavaScript form handler for data capture
- Recent activity (last update 1 week before discovery)

Potential victim impact

- Login credential theft
- Identity theft through personal information capture
- Financial fraud using stolen credentials
- Employment scam (pretending to process applications)
- Secondary targeting (using leaked data for further attacks)

Incident response process

Step 1: Evidence gathering

Actions Taken:

- DNS resolution and analysis

- Repository file inspection
- Malicious code identification
- Technical documentation of hosting infrastructure

Tools Used:

- nslookup (DNS resolution)
- GitHub web interface (repository inspection)
- Manual code review
- OSINT techniques (passive investigation using publicly available data only)

Step 2: Documentation

Created:

- Formal incident report (comprehensive)
- GitHub support message (concise)
- Technical evidence compilation
- Impact assessment

Documentation Quality: High

- Technical details included
- Clear violation references
- Supporting evidence provided
- Timeline established

Step 3: Multi-channel reporting

Primary Channel - GitHub Abuse Report Form

- URL: https://github.com/contact/report-abuse
- Date Submitted: April 2, 2026
- Category: Phishing / Impersonation
- Time to Submit: <30 minutes
- Response: Confirmed via email

Secondary Channel - Direct Support Message

- Platform: GitHub Support chat/messaging
- Date Submitted: April 2, 2026
- Concise format for immediate visibility
- Backed up primary submission

Tertiary Channel - Email to abuse@github.com

- Date Submitted: April 2, 2026
- Formal documentation
- Created paper trail
- Ensured escalation path

Why Multiple Channels?

- Increases visibility with different teams
- Provides redundancy if one channel missed
- Demonstrates reporter seriousness
- Creates multiple evidence trails

Step 4: Tracking and follow-up

Tracking Elements:

- Submission dates recorded
- Reference numbers captured
- Response times monitored
- Confirmation documentation saved

Follow-up Status:

- Initial report: April 2, 2026
- GitHub confirmation: September 8, 2026
- Status checked regularly
- Closure documented

GitHub's response

Official confirmation

From: GitHub Trust & Safety (deve...@githubsupport.com)

Date: September 8, 2026, 2:27 PM UTC

Subject: Report Abuse: kenblogme (user)

Statement:

"Our review of the account(s) and/or content named in your report has concluded. We have determined that one or more violations of GitHub's Terms of Service have occurred and have taken appropriate action in response."

Actions confirmed

Action	Status	Date
Enforcement action taken by GitHub	✓ Confirmed in GitHub's email	Sep 8, 2026
Phishing site taken down	✓ Verified by reporter (visited the site)	—
Account suspension, repository removal and CNAME revocation	Not itemised in GitHub's email	—

Violations found

GitHub confirmed the following violations of their Terms of Service:

1. **Phishing and Social Engineering** - Fake employment portal design
2. **Impersonation** - False government entity representation
3. **Credential Harvesting** - offer.js form capture mechanism
4. **Fraud** - Deceptive employment scheme

Incident resolution

What was stopped

Immediate Threats Eliminated:

- ✓ Malicious domain no longer accessible
- ✓ Credential capture mechanism offline
- ✓ Fake employment portal removed
- ✓ Account prevented from future abuse

Victim Protection:

- No new victims can be recruited
- Existing victims' data no longer collected
- Attack infrastructure dismantled
- Account cannot be repurposed

Residual actions (optional)

Recommended Follow-ups:

1. Report to Electoral Commission of Zambia
    - Status: Pending
    - Purpose: Alert official institution
    - Action: Notify public of threat removal
2. Report to domain registrar (alloffer.org)
    - Status: Pending
    - Purpose: Document CNAME misuse
    - Action: Prevent future similar attacks
3. Report to Zambian cybersecurity authority (CERT-ZM)
    - Status: Pending
    - Purpose: National incident coordination
    - Action: Public awareness campaign

Incident response methodology used

Framework applied

This incident response followed standard InfoSec incident handling practices:

1. **Detection & Analysis ✓**
    - Suspicious domain identified
    - Technical investigation conducted
    - Malicious intent confirmed
2. **Containment & Reporting ✓**
    - Multi-channel abuse reports submitted
    - Evidence documented
    - Proper escalation followed
3. **Eradication & Recovery ✓**
    - GitHub confirmed action taken
    - Account suspended
    - Repository removed
4. **Post-Incident Activity ✓**
    - Documentation completed
    - Case study documented
    - Timeline recorded

Key process strengths

- **Technical Rigor:** DNS analysis + code inspection provided clear evidence
- **Documentation:** Formal report reduced response friction
- **Multi-Channel Approach:** Increased likelihood of swift action
- **Persistence:** Follow-up ensured confirmation
- **Completeness:** All evidence preserved for the record

Lessons learned

What worked well

1. **DNS Investigation as First Step**
    - Quickly identified GitHub Pages hosting
    - Provided immediate technical proof
    - Reduced ambiguity
2. **Code Review for Intent**
    - offer.js clearly demonstrated credential harvesting
    - Eliminated any possibility of legitimate use case
    - Accelerated abuse team review
3. **Multi-Channel Reporting**
    - Multiple channels increased visibility
    - Redundancy ensured report didn't get lost
    - Demonstrates reporter expertise
4. **Formal Documentation**
    - Professional report format respected
    - Clear violation references
    - Easy for abuse team to verify

Areas for future improvement

1. **Faster Escalation**
    - The response took about 5 months, which is slow for a live phishing site
    - Consider escalation to platform contacts
    - Could identify official reporting channels
2. **Proactive Victim Notification**
    - Could have researched if ECZ had official communication
    - Victim awareness could prevent related attacks
    - Coordinated response demonstrates impact
3. **Registry Coordination**

- Report domain registrar simultaneously
- Prevent attacker from moving domain
- Coordinate cross-platform takedown

Threat intelligence insights

- **Government Impersonation is Effective in Developing Markets**
  - Trust in official institutions is high
  - Employment/recruitment are vulnerable vectors
  - Tech literacy may be lower for some targets
- **GitHub Pages is Abused for Phishing**
  - Free hosting enables scalable attacks
  - CNAME feature enables domain spoofing
  - GitHub acted once its review concluded, though the review took about five months
- **JavaScript Form Handlers are Common**
  - Simple but effective credential capture
  - Can exfiltrate to any endpoint
  - Easy to implement for non-technical attackers

Real-case study

What this case demonstrates

Technical Skills:

- DNS analysis and infrastructure mapping
- Code review and malicious intent identification
- Technical documentation and evidence compilation

Process Skills:

- Incident identification and triage
- Multi-channel escalation

- Professional communication
- Follow-up and persistence

Security Mindset:

- Proactive threat identification
- Impact assessment (social dimension)
- Vulnerability to government impersonation
- Public responsibility

Real-world impact

What happened:

- A real phishing email led to a fake Electoral Commission of Zambia careers portal
- The site targeted Zambian citizens seeking government employment
- A JavaScript form handler (offer.js) was built to capture credentials and personal data

How it was handled:

- Investigated with OSINT, using publicly available data only
- Reported to GitHub through the abuse form, a direct support message and abuse@github.com
- GitHub Trust & Safety confirmed on September 8, 2026 that its review had concluded and action was taken

What remains:

- Report to the Electoral Commission of Zambia (pending)
- Report to the domain registrar for alloffer.org (pending)
- Report to CERT-ZM (pending)

Appendix: Supporting evidence

DNS resolution output

```
Server:         127.0.0.53
Address:        127.0.0.53#53
```

```
Non-authoritative answer:
ecz-career.alloffer.org  canonical name = kenblogme.github.io.
Name:  kenblogme.github.io
Address: 185.199.109.153
Address: 185.199.108.153
Address: 185.199.111.153
Address: 185.199.110.153

IPv6 Addresses:
2606:50c0:8000::153
2606:50c0:8003::153
2606:50c0:8002::153
2606:50c0:8001::153
```

GitHub confirmation email

From: GitHub Trust & Safety

Date: September 8, 2026

Status: Violations confirmed, action taken

Document history

Version	Date	Changes
1.0	Sep 8, 2026	Initial incident documentation complete
1.1	Sep 8, 2026	Added GitHub confirmation and resolution details
1.2	Oct 13, 2026	Reframed as a real-case study; corrected response time and hosting details

Document Classification: Public – Real-world case

Distribution: Public

Retention: Permanent

End of Incident Documentation